

Veille n2 - La Securite des APIs REST

BTS SIO SLAM | Imdad BOURAIMA | 2025-2026

Informations generales

Sujet	Les bonnes pratiques et menaces liees a la securisation des APIs REST
Objectif	Adopter une approche Security by Design dans mes developpements
Periode	Janvier 2026 - Mars 2026
Sources	OWASP API Security Top 10, PortSwigger Blog, Newsletter ANSSI, YouTube (Fireship)

Tableau de synthese - OWASP API Security Top 10 (selection)

Vulnerabilite	Description	Contre-mesure
Broken Object Level Auth.	Acces aux ressources d un autre utilisateur via l ID	Verifier les droits a chaque requete cote serveur
Broken Authentication	Tokens mal geres, secrets faibles, pas de verification	JWT avec expiration courte + refresh token securise
Excessive Data Exposure	L API retourne plus de donnees que necessaire	Filtrer les reponses, exposer uniquement les champs utiles
Injection SQL / NoSQL	Requetes malveillantes injectees via les parametres	Utiliser des requetes preparees (PDO en PHP)
Rate Limiting absent	Attaques par force brute ou DoS possibles	Limiter les requetes par IP et par token

Bonnes pratiques adoptees dans mes projets

Pratique	Outil / Methode	Projet concerne
Authentification securisee	JWT + HTTPS	LegalHelp, Plateforme Joueurs
Validation des entrees	PDO / requetes preparees	Tous les projets PHP
Gestion des roles	Admin / Super Admin / User	Plateforme Joueurs (Divrsitee)
Chiffrement des communications	HTTPS obligatoire	Dashboard Data (APIs tierces)

Actualites cles suivies

Date	Sujet	Source	Enseignement
Mars 2026	OWASP API Security Top 10 - ed. 2025	owasp.org	Nouvelles vulnerabilites liees aux APIs d IA (prompt injection)
Jan. 2026	Les failles JWT en pratique	PortSwigger Blog	Algorithme none, secrets faibles : erreurs courantes a eviter
Dec. 2025	Fuite via surexposition API	ANSSI Newsletter	Ne jamais exposer les champs sensibles dans les reponses JSON

Impact sur le metier de developpeur SLAM

- Systematiser l utilisation de PDO et des requetes preparees en PHP.
- Valider et filtrer toutes les donnees recues cote serveur.
- Mettre en place une gestion des tokens JWT avec expiration et revocation.
- Documenter les endpoints et restreindre l acces selon les roles utilisateurs.